

MITRE ATT&CK Framework, Sysmon & Sigma

MITRE ATT&CK

Introduction

MITRE ATT&CK is a framework that maps out how adversaries think and behave once they've infiltrated a system.

It was created by the company MITRE and stands for Adversarial Tactics, Techniques & Common Knowledge.

This framework is used by cyber industry professionals to standardise communication regarding cyber threat.

Tactics

Tactics are what an attacker tries to do/achieve.

This can include things like:

Gaining initial access

Further attack

Persistence

Privilege Escalation

Exfiltration

Lateral Movement

Techniques

Techniques are how an attacker tries to achieve those goals

This can include things like:

Phishing

Password spraying

Credential stuffing

Technique IDs

Techniques are given unique "Technique IDs". These are used to label and identify the specific technique used. For example, if the attacker creates a new account, the technique ID for this would be T1136.

Techniques can have subcategories. For example, creating an account could have different subcategories like creating a local account, creating a domain account and creating a cloud account. Thus, sub-techniques are also given unique IDs but as subcategories of the original. For example:

Local account creation: T1136.001

Domain account creation: T1136.002

Cloud account creation: T1136.003

Note: Technique IDs don't change even if the technique name itself changes. This is to help maintain that standardised communication.

Mitigations

Each technique given in the framework is linked to common defensive measures.

For example, the technique T1112 (Modify Registry) has the following possible mitigations:

Restrict registry permissions

Monitor changes made to the registry

etc.

Sysmon

Introduction

Sysmon (System Monitor) is a Windows logging system created by Microsoft to provide more detailed event logs.

Windows, by default, provides logs that significantly lack detail which can make forensic investigations post-incident much more difficult.

Sysmon can provide details like:

The account doing the activity

Exact command lines executed

Timestamps

Parent processes

Sysmon Logs

Sysmon logs events with event IDs to uniquely identify the type of event that happened (similar to how the MITRE ATT&CK framework provides technique IDs to uniquely identify the type of techniques used by the adversary).

Examples of event IDs:

1: Process creation

3: Network connection

10: Process access

11: File creation

Example of Sysmon Logs for Event ID 1 (Process Creation):

Process:

powershell.exe

Command Line:

powershell -EncodedCommand ...

Parent:

explorer.exe

User:

Administrator

SHA256:

[]

Event Viewer

Event Viewer is the built-in log reader in Windows.

It helps read logs that constantly record things happening within the OS such as programs starting, errors, logins, security events etc.

The logs contain all this information and the Event Viewer is just the app that lets the user read those logs in a GUI.

Sysmon can work with Event Viewer. Sysmon actually makes the logs and Event Viewer can be used to display that log data in an easy-to-see way for the user.

Log Categories

Microsoft split the types of logs up into different categories:

Operational: logs of real-time system activity (what we want when analysing malware effects with Sysmon)

Analytical: diagnostic logs

Debug logs: developer-level logs related to Windows code development

So, to analyse malware behaviour in Windows, you should first run the malware sample in a VM/sandbox. Capture events with Sysmon and use Event Viewer to view Operational Sysmon logs, filter and analyse.

Malware Dev Blue-Team Project Notes

MITRE ATT&CK Framework Notes:

- T1547.001 for registry run keys - it modified registry run keys to be able to run on startup
- T1136.001 local account creation (created a local administrator account)
- T1112 for registry modification (disabled uac and installer detection)
- T1059.003 for Windows Command Shell (CMD) usage

Sysmon Event IDs:

T1547.001

Event ID 12: RegistryEvent (Object create and delete) because I created a new registry value in the Run part to run on startup.

Event ID 13: RegistryEvent (Value set) because after creating that new registry value, the virus set it the value of its file path.

T1136.001

Event ID 1: Process Creation (invoked CMD commands creating a CMD process) to create a new administrative user.

Event ID 5: Process terminated (CMD process was terminated after command execution finished to create the new user).

T1112

Event ID 13: RegistryEvent (Value set) because I set values for registry values to disable UAC and installer detection and ConsentPromptBehaviourAdmin.

T1059.003

Event ID 1: Process Creation (invoked CMD commands creating a CMD process) to create a new administrative user.

Event ID 5: Process terminated (CMD process was terminated after command execution finished to create the new user).

Misc.

Event ID 1: Process Creation (the .exe executes modifying Registry in a process and invoking CMD process).

Event ID 11: File appears on disk (malware downloaded).

Event ID 29: File downloaded (malware downloaded). The SwiftOnSecurity Sysmon Config XML file accounts for file downloads in sensitive, high-risk folders like the Downloads and Desktop folders. It does **not** check every folder on disk where the file may be downloaded.

Note: Sysmon Event ID includes any process being created (e.g., notepad.exe, fileexplorer.exe, cmd.exe etc.).

Note: It's important to use Sysmon along with Windows Security logs (they are not enough on their own). Sysmon tells you event IDs like process creation but won't tell you exactly what process was created. Windows Security logs on its own won't tell you information like the full command line being executed.

Sigma Rule Writing

Introduction

Sigma rules are written to help identify odd/malicious behaviour in log files, usually used in conjunction with a SIEM.

They have a few components:

- Detection (what we are looking for)
- Logsource (what logs to be reading for this rule)
- Metadata (what the rule is - a description)
- Condition (when does it trigger identification?)
- Level (how serious the behaviour detected is)
- Tags (what MITRE ATT&CK techniques it maps to)

Sigma Structure

Title

This part of the Sigma rule is a name for the detection (what it's looking for/targeting) for people to understand.

General Format:

[Behaviour] through/via/by [Technique/Mechanism]

ID

These are **globally unique** IDs for the rule to help track it. Cybersecurity communities around the world will be referencing Sigma rules for SIEMs etc.

Status

Status of the Sigma rule tells us how it should be treated.

- Experimental: not production-tested/production-grade
- Stable: widely-tested rule that is accepted and not experimental
- Test: currently being tested to evaluate how effective it is as a rule. It sits between experimental and stable
- Unsupported/deprecated: the rule is outdated/replaced/no longer works

Description

An explanation of what the rule detects/looks for. Should be a one-liner. Don't say Event ID - actually describe what the rule is doing.

Example: "Detects modification of Windows Run registry key used for persistence by malware".

Author

Who wrote the rule.

Date

This is the "date" field telling you the date the Sigma rule was created.

Modified

This is the "modified" field telling you the last date the Sigma rule was edited.

Logsource

The logs that are actually being searched by the rule.

It contains two categories (write with indentation):

- product: The Operating System on which the logs are created
- service: The log providing service (e.g., Sysmon)

This tells the Sigma rule what type of logs to focus on as a rule.

Detection

This section specifies exactly what triggers the alert.

It can contain different categories (write with indentation):

- "selection": A group of conditions (write as indented). All of these things must match for the rule to function. A selection clause can contain stuff like:
 - EventID: [Event ID]
 - TargetObject|contains: '\Run\
→ This one means "registry path includes this string" so that it can apply to any registry path containing that "\Run\" string.

Example:

```
detection:
  selection:
    EventID: 13
    TargetObject|contains: '\Run\'
    Image|endswith: '\malware.exe'
  condition: selection
```

→ End with a "condition" statement to tell the YAML file that the condition is the "keywords" listed to look out for.

Note: The values written in "EventID" represent the Event IDs used in the service for logging you specify in the YAML file. We are using Sysmon so the EventIDs specified will correspond to Sysmon EventIDs. To list multiple EventIDs, list them with the "-" operator as an indented list (explained below)

- "keywords": a list of strings (written with an indentation with "-" at the start) that the rule is looking for. This "-" operator essentially means "OR" between the strings listed.

Example:

```
detection:
  keywords:
    - "rm *bash_history"
    - 'echo "" > *bash_history'
    - "truncate -s0 *bash_history"
    - "history -c"
    - "history -w"
  condition: keywords
```

→ End with a "condition" statement to tell the YAML file that the condition is the "keywords" listed to look out for.

Note: If you have multiple "selection" clauses (e.g., selection1:, selection2:), you can group them in the condition clause with the "and" and "or" operators to combine the groups of conditions in specific ways. **Remember to group appropriately if you have multiple selection clauses for a Sigma rule - split them according to how you want your condition to decide how to trigger the alert.**

Level

Tells readers the severity of the threat the Sigma rule is looking for.

- Low: informational
- Medium: suspicious (e.g., terminal invocation)
- High: likely malicious (e.g., Run key persistence in Registry; user creation) - has a chance of being benign.

- Critical: active compromise (e.g., UAC disabled)

Tags

This is where the threats being scanned for are mapped to specific techniques from the MITRE ATT&CK Framework (specified using Technique IDs).

Example:

```
tags:  
  - attack.execution  
  - attack.t1059.003
```

- List all the tags, again using the OR operator ("").
- First write the actual ATT&CK tactic being used and then write the exact Technique ID. This quickly tells readers what the Sigma rule is scanning for, without having to look up the exact Technique ID. You **don't need to do this** but it can help.

References

These are URL links, again listed with the "-" operator to web pages that explain why the Sigma rule was necessary, what it helps to do etc.

This is optional but helps.

Learning Notes on Sigma Rule Writing:

- If you have 2 different selection statements with 2 different Event IDs, you can't combine the selection statements with "and" in "condition". This is because 2 different event IDs will never happen **at the same time** (consecutively in a very short time span is **NOT** the same).
- Don't use "\\Run\\" as the TargetObject\\contains field. This tells Windows to trigger the rule if the registry path contains the text "Run" anywhere, even if the path is completely unrelated and happens to contain the word "Run" somewhere. Use "\\CurrentVersion\\Run" instead to specify the Run folder. Remember, searching is usually case-insensitive for different SIEMs (e.g., Splunk, Sentinel, Elastic by default) but you can have case-sensitive for other SIEMs.

- The "contains" keyword in TargetObject|contains is like a wildcard that means "the string you're looking for contains this substring". You could also replace it with "startsWith" which means "the string you're looking for starts with this substring" and "endsWith" which is self-explanatory.
 - If using Sysmon, don't end Registry paths to search for with a \ trailing at the end. This is because Sysmon doesn't add this onto the end of the Registry path in the logs so the Sigma rules will miss the event because it's not the exact same string.
 - You can use Image|endwith:'\applicationname.exe' to specify the specific application to look out for. Image = what was executed. You can use this with cmd.exe for example and have CommandLine|contains to specify key words to watch out for in command line execution with CMD or any other application with a command line field. Most applications (e.g., Browser, Notepad etc.) will have a command line field and this is basically how the application is executed on a CLI (e.g., notepad.exe C:\temp\file.txt).
 - You can also use the "user:" tag to specify which user to look out for.
-